

Enterprise Identity and Access Management Security Lab

A Complete Practical Implementation of Centralized Identity Management, Single Sign On, Role Based Access Control, and Multi Layered Secure Remote Access

Table of Contents

Enterprise Identity and Access Management Security Lab	1
Executive Summary	4
Chapter 1: Introduction	5
Chapter 2: Project Objectives	6
Chapter 3: Background and Why This Matters	6
Diagram:.....	7
Chapter 4: Project Overview and Company Simulation	8
Chapter 5: System Requirements and Environment	8
Chapter 6: Network Architecture	9
Diagram :	10
Chapter 7: Tools and Technologies Used	10
Chapter 8: Detailed Implementation, Active Directory	11
Screenshot.....	11
Diagram.....	12
Chapter 9: Detailed Implementation, Authentik Single Sign On	12
Screenshot:.....	12
Screenshot.....	13
Chapter 10: Detailed Implementation, Department Applications	14
Screenshot.....	14
Screenshot.....	15
Chapter 11: Detailed Implementation, Firewall and VPN Gateway	15
Screenshot:.....	16
Screenshot :	16
Screenshot.....	16
Screenshot.....	17
Diagram.....	17
Chapter 12: Detailed Implementation, FreeRADIUS and Least Privilege	18
Diagram:.....	18
Chapter 13: Two Factor Authentication, Implemented at Two Separate Layers	19
13.1 Web Login Two Factor Authentication (Authentik)	19
Screenshot.....	20
Screenshot:.....	20
13.2 VPN Login Two Factor Authentication (FreeRADIUS)	21

Chapter 14: Security Analysis and Risk Reduction	22
Chapter 15: Testing and Results Summary	23
Chapter 16: Conclusion	23

Executive Summary

This report documents the design, implementation, and testing of a complete Identity and Access Management security lab built entirely inside a virtualized environment. The project simulates a small but realistic company network with three departments, each protected by centralized authentication, role based access control, and multi factor authentication enforced at two separate points of entry: normal web based logins and remote VPN connections.

The lab was built using four virtual machines working together as a single system: a Windows Server acting as the identity source, an Ubuntu server running the identity provider and department applications, a firewall acting as the network boundary and VPN gateway, and a client machine used for testing. Every access decision in this system, whether a web login or a remote VPN connection, ultimately traces back to a single, centrally managed identity record, which reflects how real enterprise networks are designed to reduce risk and simplify security management.

This report also documents, in detail, the real technical challenges encountered while building the VPN based Two Factor Authentication system, since this was the most complex and failure prone part of the project, and demonstrates the diagnostic process used to resolve each issue using log analysis rather than guesswork.

Chapter 1: Introduction

Every organization, no matter its size, eventually faces the same core security question: how do we make sure that only the right people can access the right systems, and how do we prove that someone really is who they claim to be. As companies grow, so does the number of employees, applications, devices, and remote workers, and with that growth comes a much larger attack surface for anyone trying to gain unauthorized access.

Historically, many organizations solved this problem badly, giving each application its own separate login system, its own separate password rules, and no central way to disable an employee's access everywhere at once when they leave the company. Modern enterprise security has moved almost entirely away from this scattered approach and toward a model called centralized Identity and Access Management, where one trusted system holds the truth about who everyone is, and every other system defers to it.

This project was built to understand that model by actually building it, rather than only reading about it. A small virtual company was created with three departments, each with its own employee and its own dedicated internal application, all governed by a single Active Directory identity source, a single sign on layer, and a firewall protected VPN gateway for remote access.

Enterprise Identity and Access Management Security Lab



Chapter 2: Project Objectives

1. Design and implement centralized identity management using Active Directory as the single source of truth for user identity and department membership.
2. Implement Single Sign On so that users authenticate once and gain access to every application they are authorized for, without separate logins for each system.
3. Enforce strict, group based access control so that employees can only reach applications belonging to their own department.
4. Enforce Two Factor Authentication at two distinct layers of the system: standard web application login, and remote VPN connection.
5. Configure a dedicated firewall and VPN gateway to control and secure all remote access into the network.
6. Apply the security principle of least privilege throughout the system, most notably through the use of a restricted service account rather than an administrator account for directory lookups.
7. Build genuine, hands on experience diagnosing and resolving real configuration failures, using debug logs and evidence based troubleshooting rather than trial and error guessing.

Chapter 3: Background and Why This Matters

Before describing the lab itself, it is worth explaining briefly why each major component of this project exists in real world organizations, since understanding the reasoning behind a design is more valuable than simply following steps.

Centralized identity solves the problem of scattered, inconsistent user accounts. Instead of every application maintaining its own separate list of usernames and passwords, one directory service holds the truth, and every other system asks that directory for answers. This means that when an employee leaves a company, disabling a single account instantly removes their access everywhere, rather than requiring someone to remember and manually revoke access across dozens of separate systems.

Single Sign On solves the problem of password fatigue and inconsistent login security. When users are forced to remember many separate passwords across many systems, they tend to reuse weak passwords, which becomes a serious security weakness. Single Sign On allows a user to authenticate once, through one strong, well protected login process, and then be trusted across every connected application.

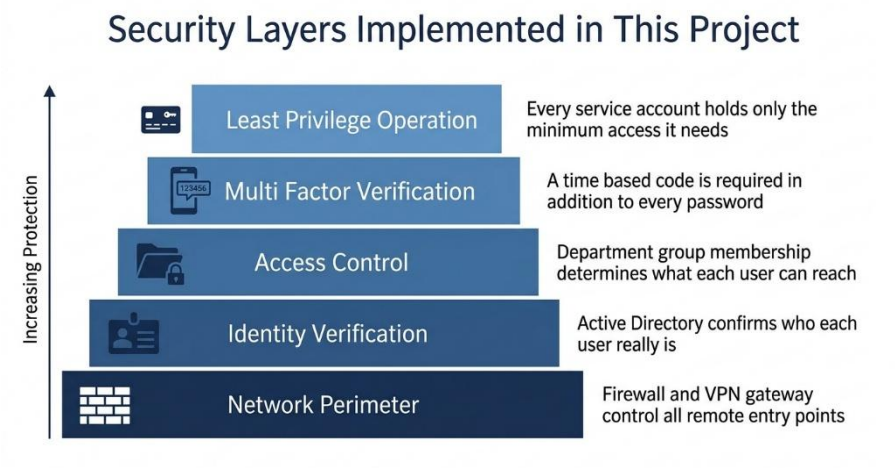
Role based access control solves the problem of overexposure. Without it, every logged in user could potentially see every system, whether or not it relates to their job. By tying access to department group membership, an employee only ever sees what their specific role requires, which limits the damage possible if any single account is ever compromised.

Multi factor authentication solves the problem of stolen or guessed passwords. A password alone proves only that someone typed the correct text, not that they are truly the account owner. Requiring a second, constantly changing factor, such as a time based code from a personal device, makes stolen passwords far less useful to an attacker on their own.

Firewalls and VPN gateways solve the problem of network exposure. Rather than exposing internal systems directly to the outside world, all remote access is funneled through one carefully controlled and monitored entry point.

Least privilege solves the problem of excessive account power. Every account, especially service accounts used by software rather than humans, should hold only the minimum permissions required to perform its specific task, so that a compromised account causes the smallest possible amount of damage.

Diagram:



Chapter 4: Project Overview and Company Simulation

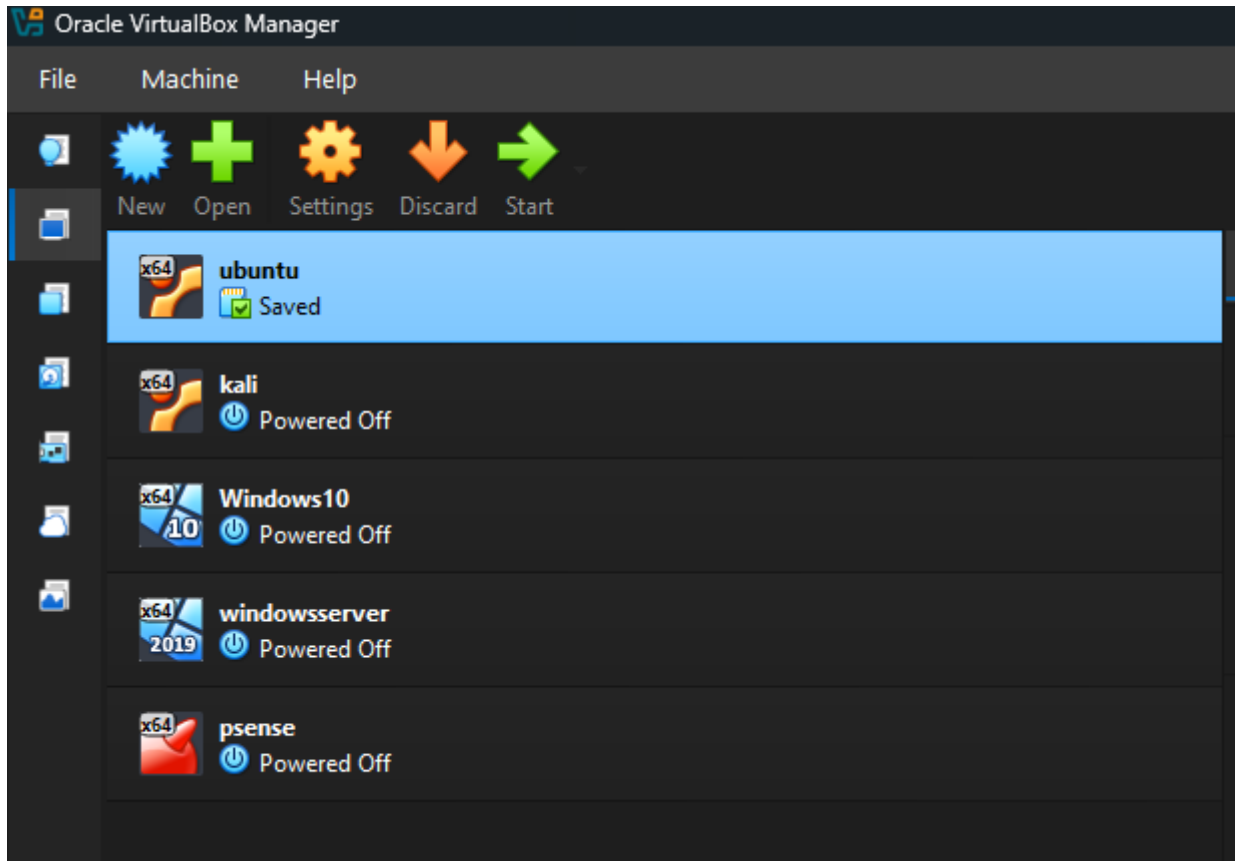
The lab simulates a fictional company with three departments, each represented by one employee and one dedicated internal web application. This structure was intentionally kept simple so that the focus of the project remains on the identity and access management system itself, rather than on building complex applications.

Department	Employee	Application Port	Application Purpose
Human Resources	Ali	5001	Represents an internal HR portal
Information Technology	Ahmed	5002	Represents an internal IT systems portal
Finance	Sara	5003	Represents an internal finance portal

Every one of these employees exists as a single record inside Active Directory, and every application defers entirely to Active Directory and Authentik for login decisions. None of the applications contain their own username or password logic, which mirrors how real enterprise applications are built to rely on a central identity provider rather than reinventing authentication individually.

Chapter 5: System Requirements and Environment

Requirement	Detail
Virtualization Platform	VirtualBox
Number of Virtual Machines	Four
Operating Systems Used	Windows Server, Ubuntu Server, Windows 10, pfSense (FreeBSD based)
Internal Network Type	Host only private network
Internal Network Range	192.168.56.0/24
VPN Tunnel Network Range	10.8.0.0/24
Domain Name Used	lab.local
Container Platform	Docker, used to run the Authentik identity provider

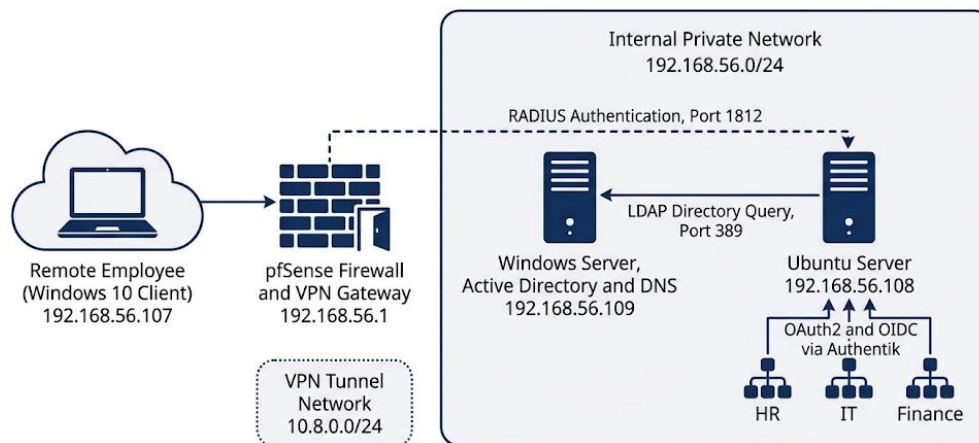


Chapter 6: Network Architecture

Machine	IP Address	Role
pfSense	192.168.56.1	Firewall and VPN gateway
Windows Server	192.168.56.109	Active Directory domain controller and DNS server
Ubuntu Server	192.168.56.108	Runs FreeRADIUS, Authentik, and the three department applications
Windows 10	192.168.56.107	Test client used to simulate an employee logging in and connecting to VPN

The private network used by all machines is 192.168.56.0/24. A separate, temporary network, 10.8.0.0/24, is used only for devices connected remotely through the VPN tunnel, and this range only exists while a VPN session is active.

Diagram :



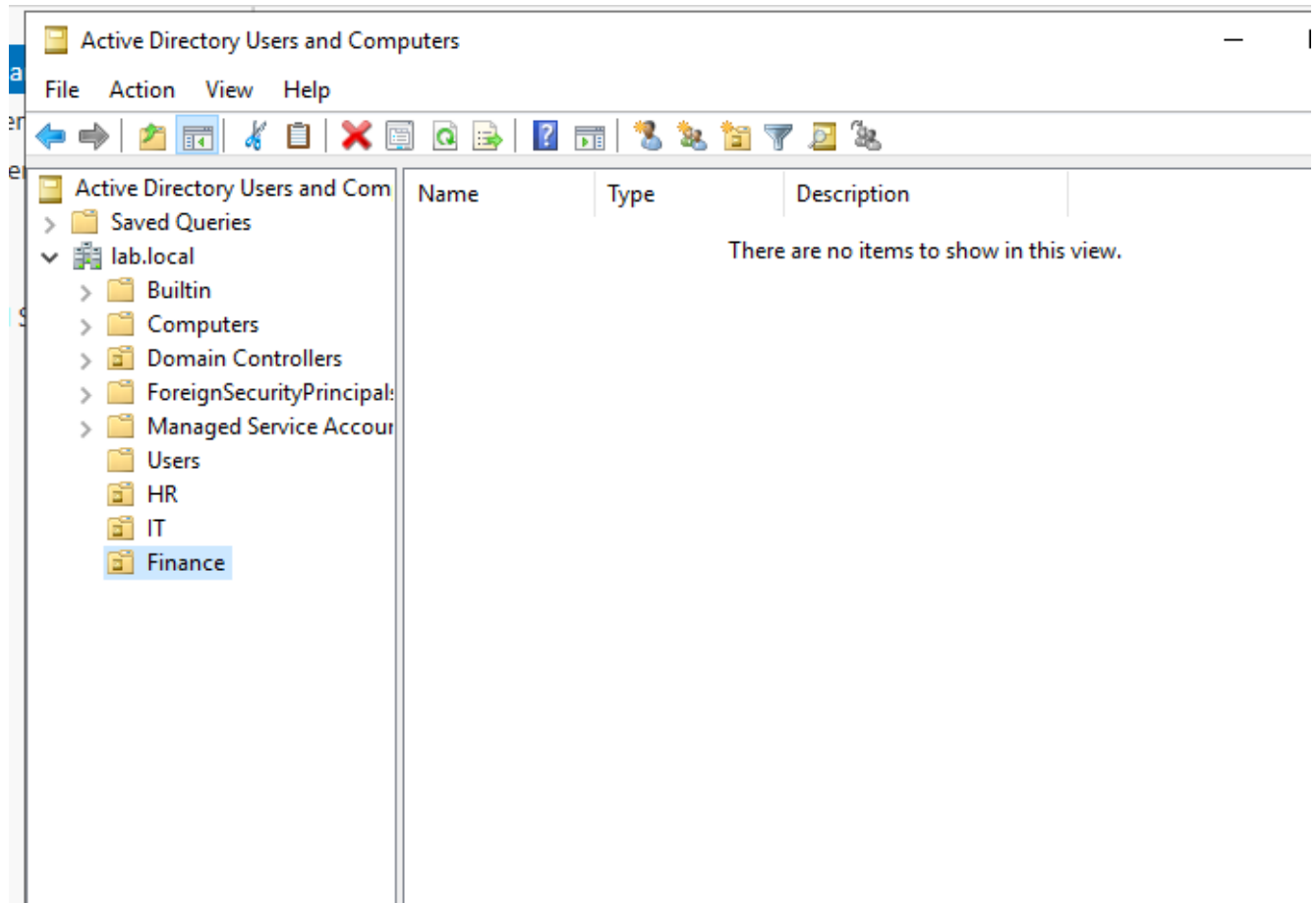
Chapter 7: Tools and Technologies Used

Tool	Category	Purpose
VirtualBox	Virtualization	Hosts all virtual machines used in the lab
Active Directory	Identity Source	Central directory of employees and their departments
Authentik	Identity Provider	Manages Single Sign On and enforces Two Factor Authentication for web applications
Flask	Application Framework	Python framework used to build the three department web applications
pfSense	Network Security	Firewall and VPN gateway software
OpenVPN	Remote Access	Software used to establish secure remote connections
FreeRADIUS	Authentication Server	Checks VPN login credentials against Active Directory
Google Authenticator PAM Module	Multi Factor Authentication	Generates and verifies time based one time passwords for VPN Two Factor Authentication
Docker	Containerization	Runs Authentik in isolated containers on the Ubuntu server
OAuth2 and OpenID Connect	Authentication Protocol	Standard protocol used between Authentik and the department applications
LDAP	Directory Protocol	Standard protocol used by FreeRADIUS and Authentik to query Active Directory

Chapter 8: Detailed Implementation, Active Directory

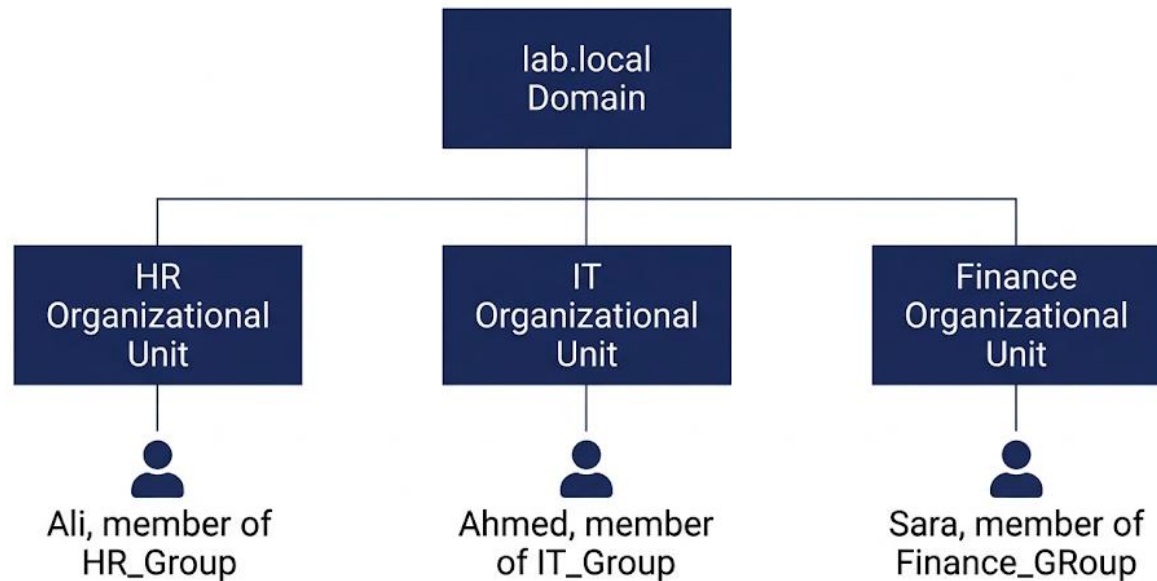
Active Directory was configured on the Windows Server machine with the domain name lab.local. Three Organizational Units were created, one for each department, and each department employee was placed into their respective unit. Security groups were created to represent department membership, and these groups are what every downstream system, including Authentik and FreeRADIUS, checks against when deciding who can access what.

Screenshot



Diagram

Active Directory Structure



Chapter 9: Detailed Implementation, Authentik Single Sign On

Authentik was deployed using Docker on the Ubuntu server and configured to connect to Active Directory as its source of user information. Three applications were registered inside Authentik, one for each department, and each was bound to its matching Active Directory security group through a policy binding, meaning Authentik automatically enforces that only members of the correct department group can log into their department's application.

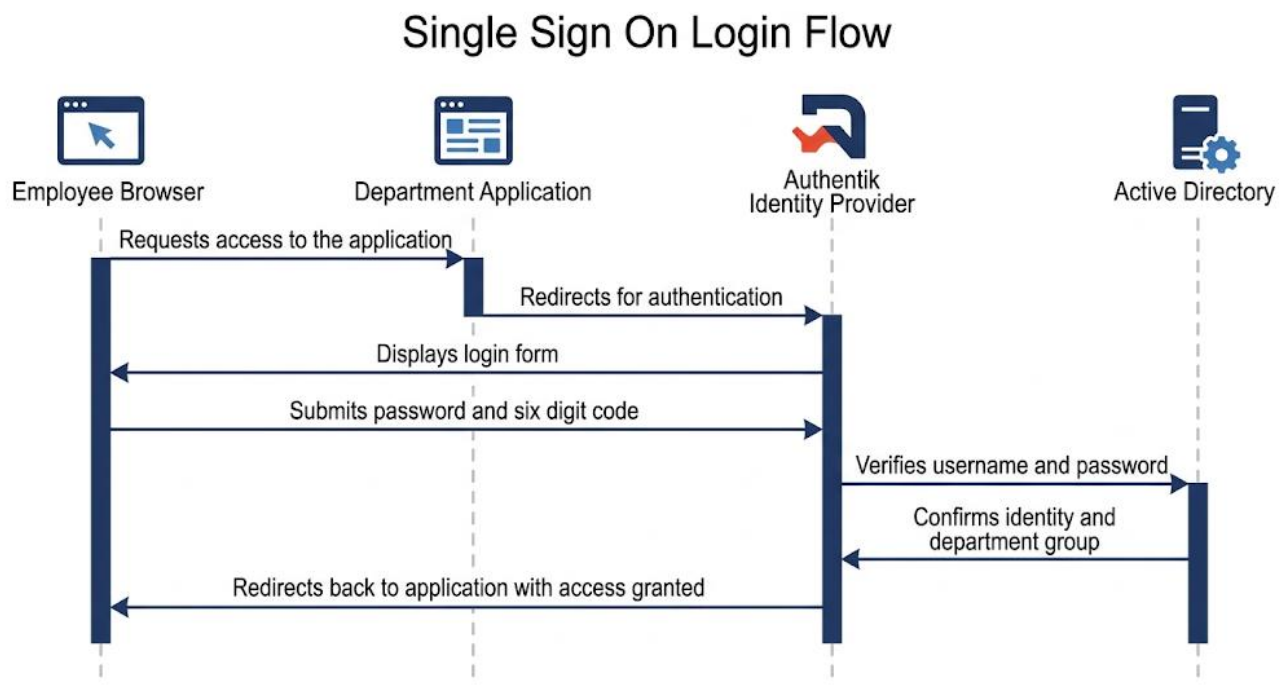
Screenshot:

```
user@ubuntu:~/authentik$ docker compose up -d
[+] Running 5/5
✓ Network authentik_default          Created
✓ Volume authentik_database          Created
✓ Container authentik-postgresql-1   Healthy
✓ Container authentik-worker-1       Started
✓ Container authentik-server-1       Started
user@ubuntu:~/authentik$
```

Screenshot



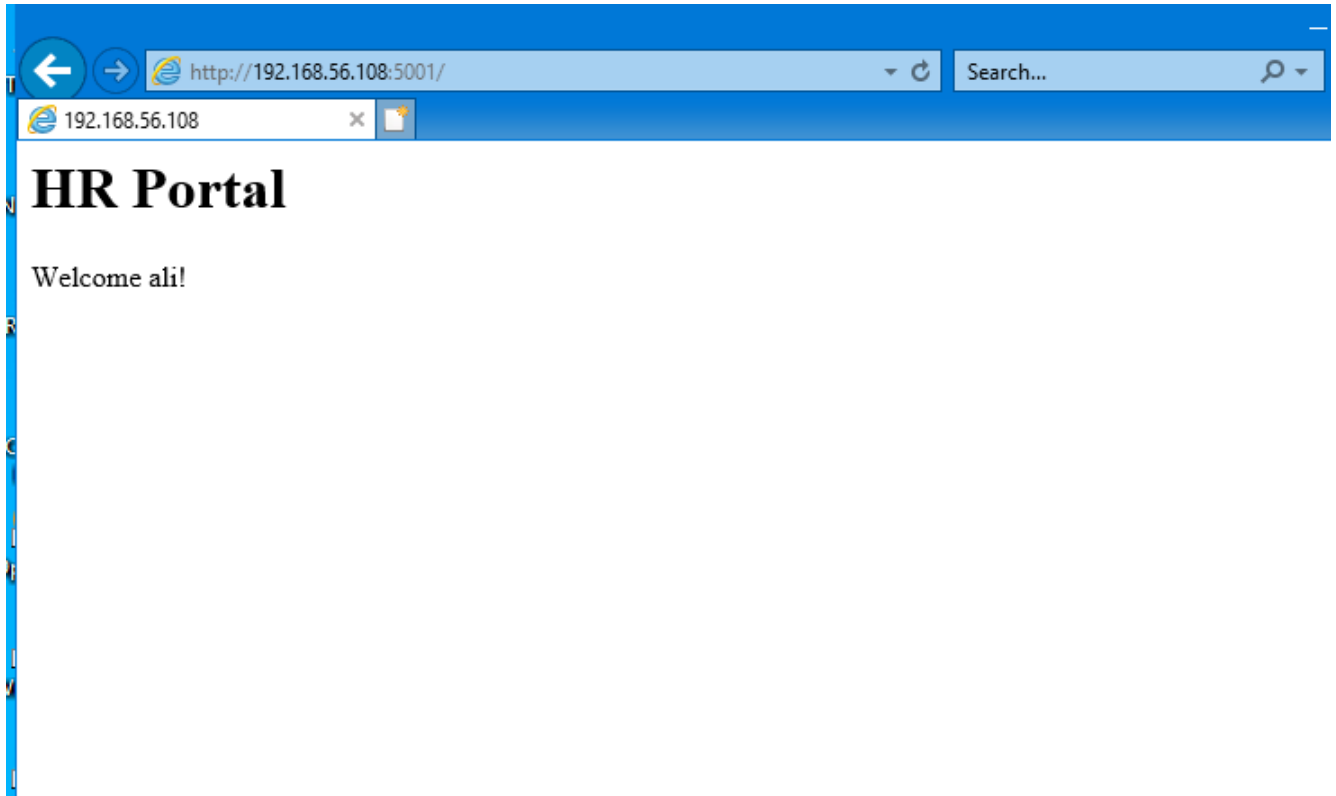
Diagram



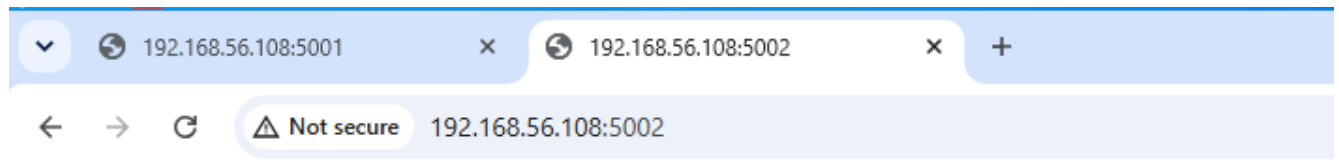
Chapter 10: Detailed Implementation, Department Applications

Three Flask based web applications were created to represent the HR, IT, and Finance systems. None of these applications contain their own login system. Instead, each one relies entirely on Authentik to confirm a user's identity and department membership before granting access, using the OAuth2 and OpenID Connect standard protocols.

Screenshot



Screenshot



Access Denied

ali is not in IT_Group

Chapter 11: Detailed Implementation, Firewall and VPN Gateway

pfSense was configured as both the network firewall and the VPN gateway for this lab. A Certificate Authority was created inside pfSense's built in certificate manager, and this Certificate Authority was used to issue a certificate for the VPN server itself. This certificate allows connecting clients to confirm they are truly speaking with the real pfSense server, and not an imposter attempting to intercept traffic.

An OpenVPN server was then configured with a dedicated tunnel network of 10.8.0.0/24, separate from the main office network, along with a route allowing connected clients to reach the main office network at 192.168.56.0/24 once connected.

Screenshot:

System / Certificate / Authorities

Authorities

Certificates

Revocation

Search

Search term

Both

Search

Clear

Enter a search string or *nix regular expression to search certificate names and distinguished names.

Certificate Authorities

Name	Internal	Issuer	Certificates	Distinguished Name	In Use	Actions
LabVPN-CA	✓	self-signed	0	CN=LabVPN-CA, C=US Valid From: Mon, 10 Aug 2026 22:58:37 +0500 Valid Until: Thu, 07 Aug 2036 22:58:37 +0500		   

+ Add

Screenshot :

System / Certificates / Certificates

Authorities

Certificates

Certificate Revocation

Search

Search term

Both

Search

Clear

Enter a search string or *nix regular expression to search certificate names and distinguished names.

Certificates

Name	Issuer	Distinguished Name	In Use	Actions
webConfigurator default (6a75e63398e6d) Server Certificate CA: No Server: Yes	self-signed	O=pfSense webConfigurator Self-Signed Certificate, CN=pfSense-6a75e63398e6d Valid From: Fri, 07 Aug 2026 19:05:39 +0500 Valid Until: Thu, 09 Sep 2027 19:05:39 +0500	webConfigurator	   
vpnuser-cert User Certificate CA: No Server: No	external	ST=Islamabad Capital Territory, OU=VPN-Cybersecurity Lab, L=Islamabad, CN=vpnuser, C=PK Valid From: Mon, 10 Aug 2026 11:16:33 +0500 Valid Until: Thu, 07 Aug 2036 11:16:33 +0500	User Cert	  
LabVPN-Server Server Certificate CA: No Server: Yes	LabVPN-CA	CN=LabVPN-Server, C=US Valid From: Mon, 10 Aug 2026 23:06:16 +0500 Valid Until: Sat, 11 Sep 2027 23:06:16 +0500		   

Screenshot

pfSense
COMMUNITY EDITION

System ▾ Interfaces ▾ Firewall ▾ Services ▾ VPN ▾ Status ▾ Diagnostics ▾ Help ▾

VPN / OpenVPN / Servers

Servers

Clients

Client Specific Overrides

Wizards

OpenVPN Servers

Interface	Protocol / Port	Tunnel Network	Mode / Crypto	Description	Actions
WAN	UDP4 / 1194 (TUN)	10.8.0.0/24	Mode: Remote Access (User Auth) Data Ciphers: AES-256-GCM, AES-128-GCM, CHACHA20-POLY1305, AES-256-CBC Digest: SHA256 D-H Params: 2048 bits	LabVPN	  

+ Add

Screenshot

System / [User Manager](#) / [Authentication Servers](#) / [Edit](#)

[Users](#) [Groups](#) [Settings](#) [Authentication Servers](#)

Server Settings

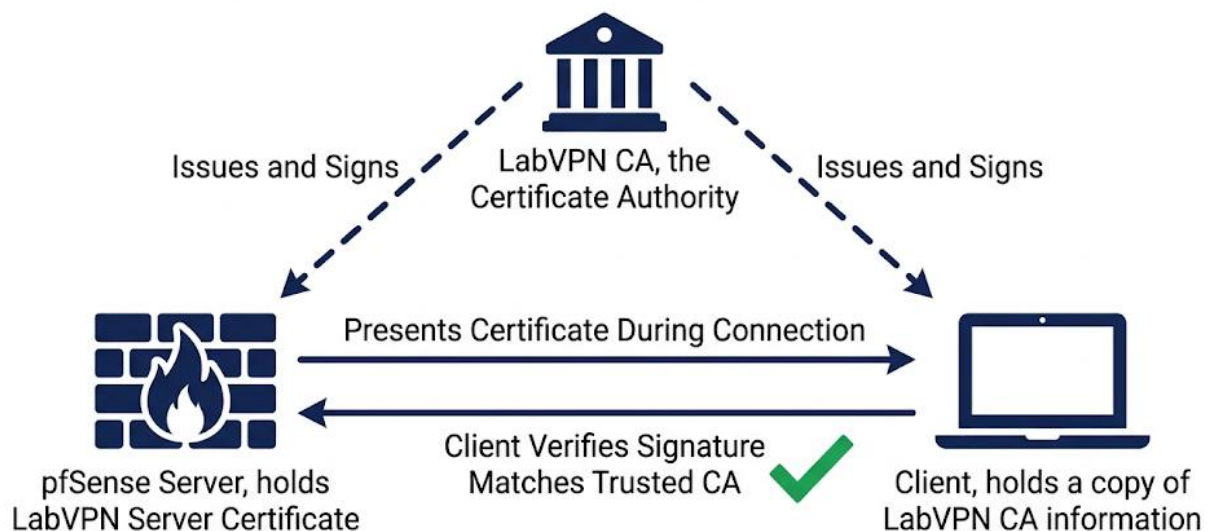
Descriptive name	FreeRADIUS
Type	RADIUS

RADIUS Server Settings

Protocol	MS-CHAPv2
Hostname or IP address	192.168.56.108
Shared Secret	*****
Services offered	Authentication and Accounting
Authentication port	1812
Accounting port	1813

Diagram

How the Client Trusts the VPN Server



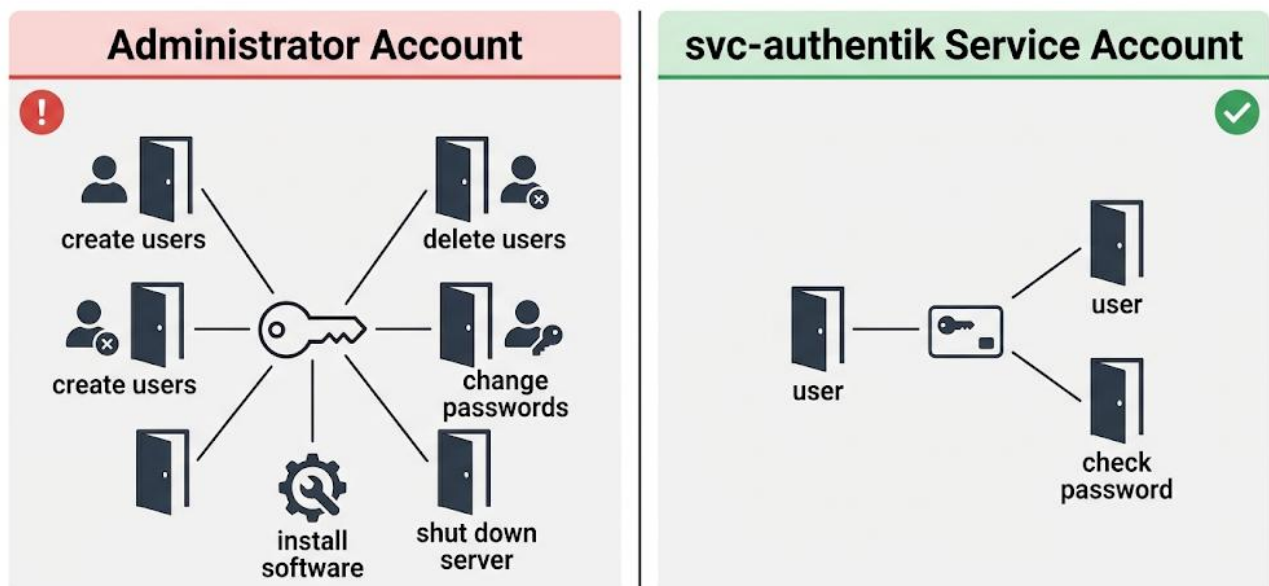
Chapter 12: Detailed Implementation, FreeRADIUS and Least Privilege

FreeRADIUS was installed on the Ubuntu server to act as the bridge between the VPN and Active Directory. It was configured to accept authentication requests only from pfSense, verified using a shared secret, and to forward password checks to Active Directory using a dedicated service account, svc-authentik, created specifically for this purpose rather than using a full administrator account.

Using a limited service account instead of an administrator account follows the security principle of least privilege, meaning every account should only be given the smallest amount of access it actually needs to do its job. This account can only look up user records and confirm whether a submitted password is correct. It cannot create, delete, or modify any account, and it can never read anyone's actual password, since Active Directory never reveals real passwords to any account, including administrators. If this limited account were ever compromised, the damage an attacker could cause would be minimal compared to the damage possible with a stolen administrator account.

Diagram:

Least Privilege in Practice



Chapter 13: Two Factor Authentication, Implemented at Two Separate Layers

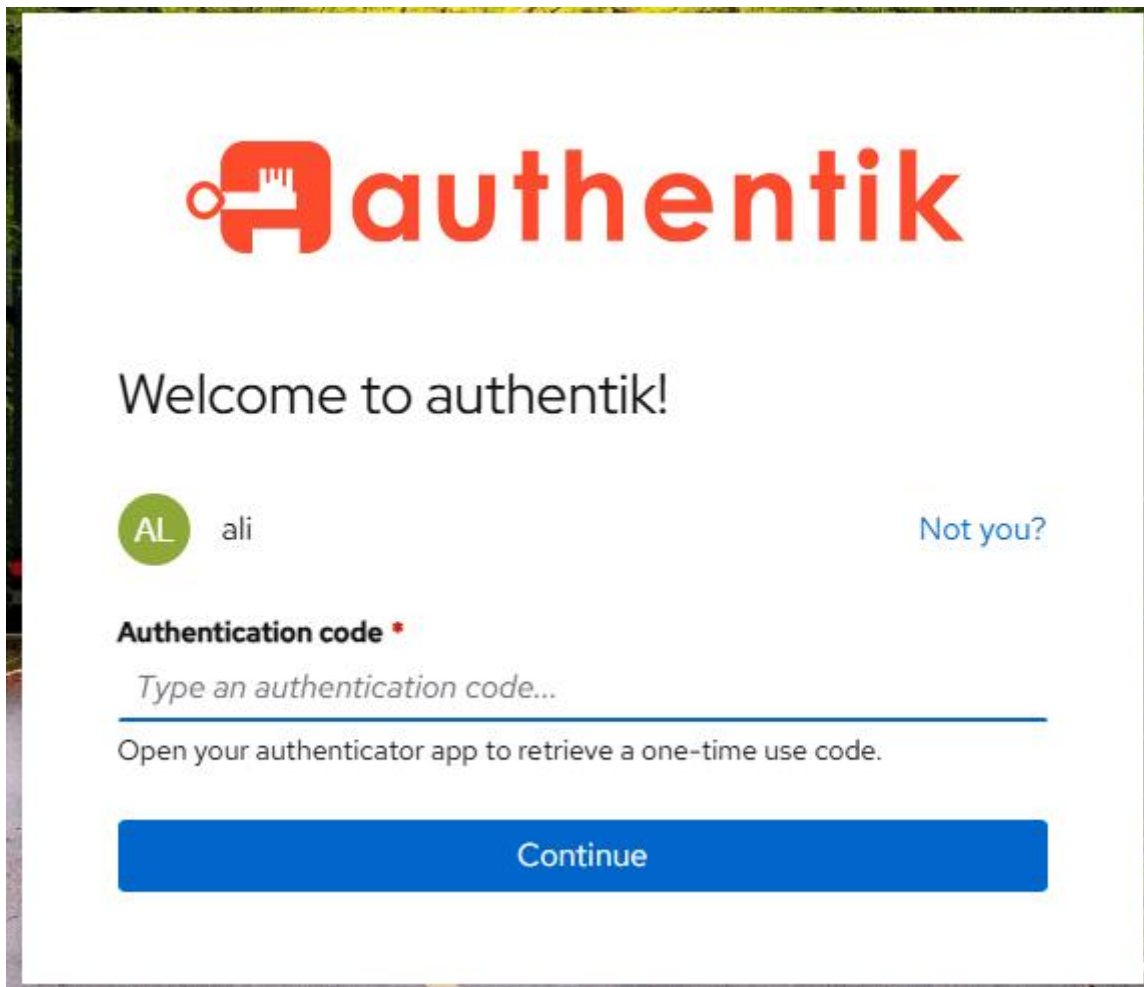
This project deliberately enforces Two Factor Authentication in two completely different places, using two different mechanisms, because each layer protects a different type of access. This chapter explains both clearly, side by side, since they are easy to confuse but work quite differently.

Aspect	Web Login 2FA, Authentik	VPN Login 2FA, FreeRADIUS
Protects access to	The three department web applications	The VPN tunnel into the private network
Where the code is entered	In a separate box, shown after the password is accepted	Typed directly after the password, in the same single box, with no space
What checks the code	Authentik's built in Authenticator Validation Stage	A PAM module linked to Google Authenticator on the Ubuntu server
Authenticator app entry used	The user's original, general login entry	A separate entry named VPN Ali, kept apart from the web login entry
What happens on failure	Authentik blocks the web login and shows an error	FreeRADIUS rejects the entire VPN connection attempt

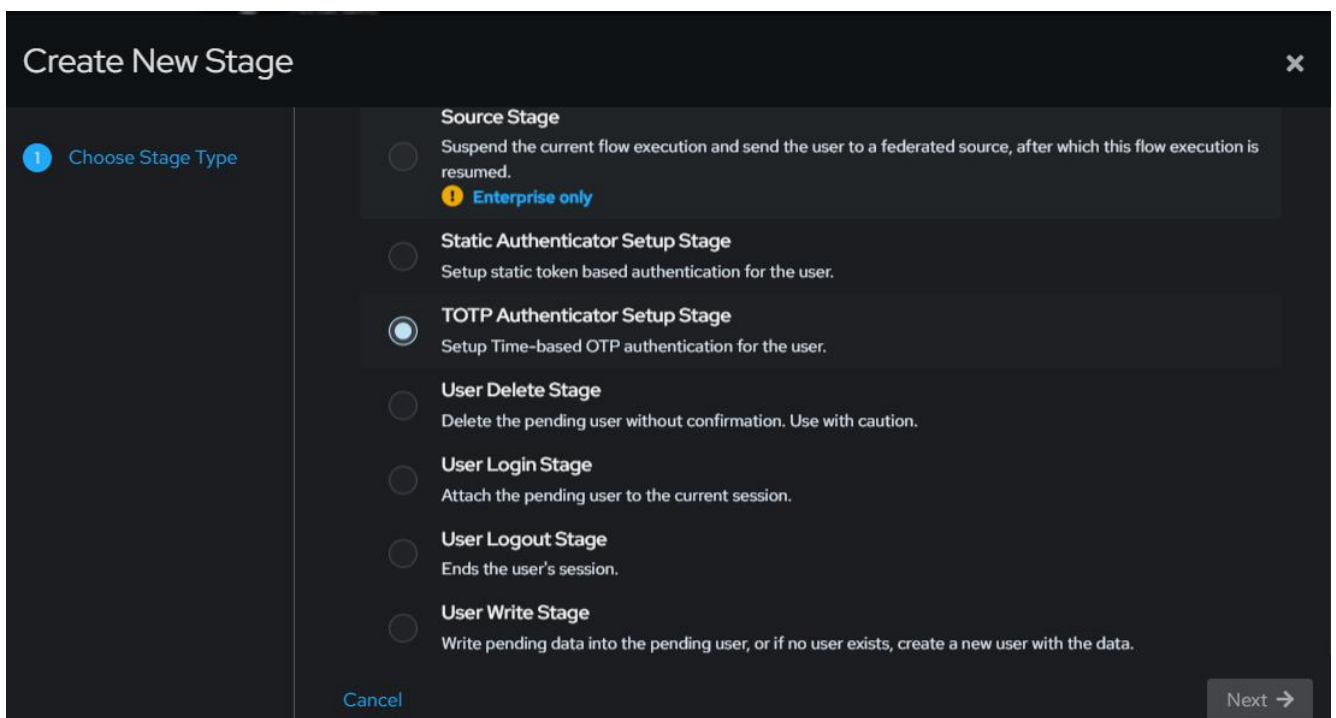
13.1 Web Login Two Factor Authentication (Authentik)

Two Factor Authentication for web logins was enabled inside Authentik using a validation stage that requires a registered authenticator device, paired with a setup stage that forces any user without a registered device to enroll one before continuing. Once enrolled, every login to any of the three department applications requires both the correct password and a currently valid six digit code.

Screenshot



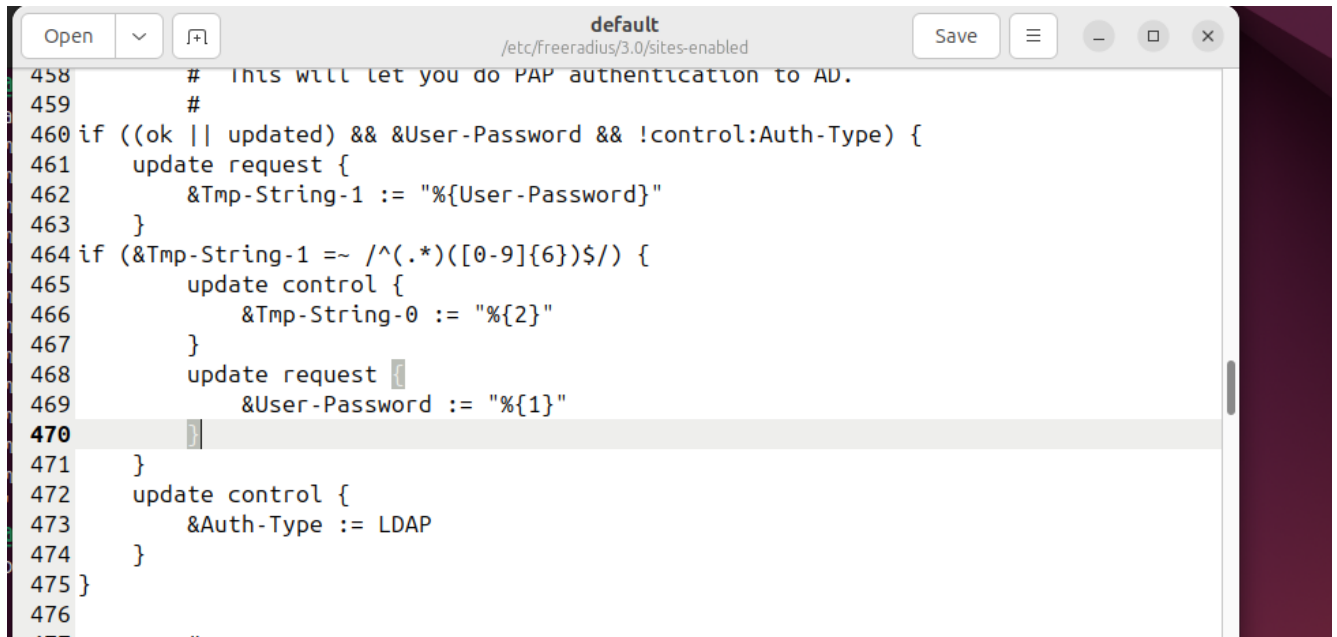
Screenshot:



13.2 VPN Login Two Factor Authentication (FreeRADIUS)

For VPN access, this lab uses a combined single field approach rather than a separate prompt. The user types their normal Active Directory password immediately followed by their six digit code, with no space, into OpenVPN's single password field. FreeRADIUS then separates this combined text using a pattern matching rule, sends the password portion to Active Directory, and sends the six digit portion to the Google Authenticator verification module. Access is granted only if both checks pass.

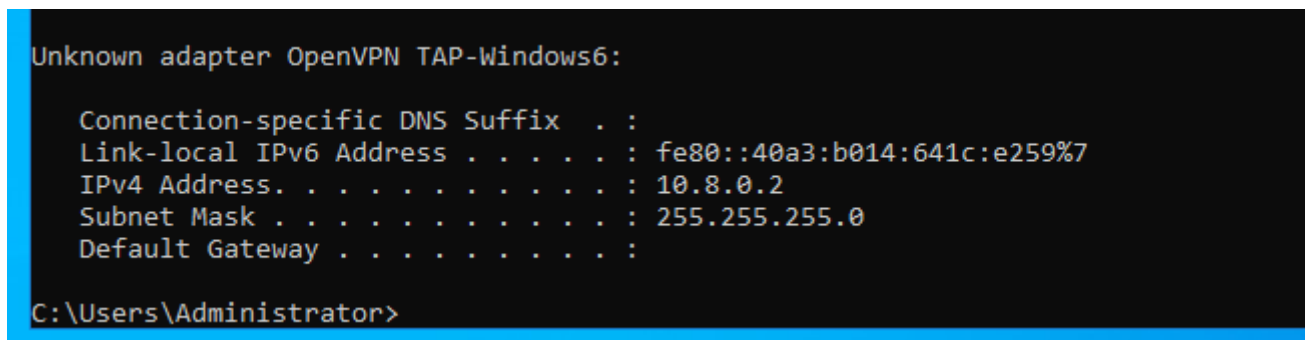
Screenshot



A screenshot of a text editor window titled 'default' with the path '/etc/freeradius/3.0/sites-enabled'. The editor shows a configuration snippet for PAP authentication. Line 458 is a comment: '# This will let you do PAP authentication to AD.' Line 459 is another comment: '#'. Line 460 is an if statement: 'if ((ok || updated) && &User-Password && !control:Auth-Type) {'.

```
458      # This will let you do PAP authentication to AD.
459      #
460 if ((ok || updated) && &User-Password && !control:Auth-Type) {
461     update request {
462         &Tmp-String-1 := "%{User-Password}"
463     }
464 if (&Tmp-String-1 =~ /^(.*)([0-9]{6})$/) {
465     update control {
466         &Tmp-String-0 := "%{2}"
467     }
468     update request {
469         &User-Password := "%{1}"
470     }
471 }
472 update control {
473     &Auth-Type := LDAP
474 }
475 }
476 ..
```

Screenshot



A screenshot of a Windows command prompt window. The title bar says 'Unknown adapter OpenVPN TAP-Windows6:'. The command prompt shows the output of the 'ipconfig' command, displaying network configuration details for the adapter.

```
Unknown adapter OpenVPN TAP-Windows6:

Connection-specific DNS Suffix  . : 
Link-local IPv6 Address . . . . . : fe80::40a3:b014:641c:e259%7
IPv4 Address. . . . . : 10.8.0.2
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :
```

The prompt is 'C:\Users\Administrator>'.

Chapter 14: Security Analysis and Risk Reduction

This chapter summarizes, in table form, how each design decision made in this project directly reduces a specific, real world security risk.

Design Decision	Risk It Reduces
Centralized identity in Active Directory	Prevents scattered accounts and forgotten access when an employee leaves
Role based access through security groups	Limits how much damage a single compromised account can cause
Single Sign On through Authentik	Reduces password reuse and password fatigue across multiple systems
Two Factor Authentication on web logins	Protects against stolen or guessed passwords alone being enough to log in
Two Factor Authentication on VPN logins	Protects the most sensitive entry point, remote network access, with the same strength of protection
Dedicated Certificate Authority for the VPN	Prevents a fake server from impersonating the real VPN gateway
Least privilege service account for directory lookups	Limits the damage possible if the service account credentials are ever leaked
Firewall controlled VPN gateway	Ensures all remote access passes through one monitored, controlled entry point rather than exposing internal systems directly

Chapter 15: Testing and Results Summary

Component	Status	Verified By
Active Directory identity management	Working	Manual login and group lookup
Authentik Single Sign On with department based access control	Working	Successful and unsuccessful login attempts across departments
Three department web applications	Working	Successful login and access to correct department only
Two Factor Authentication on web logins	Working	Login required both password and six digit code
pfSense firewall and VPN gateway	Working	Successful VPN connection from the test client
FreeRADIUS password only VPN authentication	Working	Command line test and real VPN connection
FreeRADIUS VPN Two Factor Authentication	Working	Command line test and real VPN connection using combined password and code

Chapter 16: Conclusion

This project successfully demonstrates a working, end to end enterprise identity and access management system, covering centralized identity, department based access control, Single Sign On, and multi factor authentication enforced at two separate entry points, the web application login and the VPN remote login. Beyond simply building the system, significant value came from diagnosing and resolving real configuration errors and version specific technical issues, which reflects the kind of practical problem solving skill expected in real cybersecurity and systems administration roles.

The completed lab shows a clear understanding of how identity, access control, and multi factor security work together as layered defenses, rather than as isolated features, and provides a strong practical foundation for further study or work in enterprise security, systems administration, or cybersecurity engineering.

Appendix A: Key Terminal Commands Reference

Purpose	Command
Start Authentik containers	<code>sudo docker compose up -d</code>
Check running containers	<code>sudo docker ps</code>
Check FreeRADIUS status	<code>sudo systemctl status freeradius</code>
Start FreeRADIUS in debug mode	<code>sudo freeradius -X</code>
Test RADIUS authentication	<code>radtest username password 127.0.0.1 0 testing123</code>
Verify LDAP connectivity	<code>ldapsearch -x -H ldap://192.168.56.109 -D "CN=svc-authentik,CN=Users,DC=lab,DC=local" -w PASSWORD -b "DC=lab,DC=local" "(sAMAccountName=username)"</code>
Start a Flask application	<code>python3 app.py</code>